

API Reference — Clinic Management System

Base URL: `http://localhost:8000/api` **Auth:** Bearer token (Laravel Sanctum). Pass in every protected request:

```
Authorization: Bearer {your_token}
```

Content-Type: `application/json` on all POST/PUT/PATCH requests.

Standard Response Envelope

Success

```
json
{
  "success": true,
  "message": "Resource retrieved successfully",
  "data": { },
  "meta": {
    "current_page": 1,
    "last_page": 4,
    "per_page": 15,
    "total": 60
  }
}
```

| `meta` is only present on paginated list responses.

Validation Error (422)

```
json
{
  "success": false,
  "message": "Validation failed",
  "errors": {
    "email": ["The email field is required."],
    "role": ["The selected role is invalid."]
  }
}
```

Unauthorized (401)

```
json

{
  "success": false,
  "message": "Unauthenticated."
}
```

Forbidden (403)

```
json

{
  "success": false,
  "message": "You do not have permission to perform this action."
}
```

Not Found (404)

```
json

{
  "success": false,
  "message": "Resource not found."
}
```

1. Authentication

POST `/api/auth/login`

Access: Public

Request Body:

```
json

{
  "email": "doctor@clinica.com",
  "password": "password123"
}
```

Success Response (200):

```
json
```

```
{
  "success": true,
  "message": "Login successful",
  "data": {
    "token": "1|abc123xyz456...",
    "user": {
      "id": 2,
      "name": "Dr. Sarah Ahmed",
      "email": "doctor@clinica.com",
      "phone": "01012345678",
      "role": "doctor",
      "clinic": {
        "id": 1,
        "name": "Clinic A"
      }
    }
  }
}
```

Error Response (401):

```
json
{
  "success": false,
  "message": "Invalid credentials."
}
```

POST `/api/auth/logout`

Access: All authenticated users

Headers: `Authorization: Bearer {token}`

Request Body: None

Success Response (200):

```
json
{
  "success": true,
  "message": "Logged out successfully."
}
```

GET `/api/auth/me`

Access: All authenticated users

Success Response (200):

```
json
{
  "success": true,
  "message": "User profile retrieved",
  "data": {
    "id": 2,
    "name": "Dr. Sarah Ahmed",
    "email": "doctor@clinica.com",
    "phone": "01012345678",
    "role": "doctor",
    "is_active": true,
    "clinic": {
      "id": 1,
      "name": "Clinic A",
      "address": "123 Main Street, Cairo"
    }
  }
}
```

2. Super Admin — Clinics

GET `/api/super-admin/clinics`

Access: Super Admin only

Query Parameters:

Param	Type	Example	Description
<code>page</code>	integer	<code>?page=2</code>	Page number
<code>per_page</code>	integer	<code>?per_page=10</code>	Items per page
<code>search</code>	string	<code>?search=cairo</code>	Search by name or address
<code>is_active</code>	boolean	<code>?is_active=1</code>	Filter by active status

Success Response (200):

json

```
{
  "success": true,
  "message": "Clinics retrieved successfully",
  "data": [
    {
      "id": 1,
      "name": "Clinic A",
      "address": "123 Main Street, Cairo",
      "phone": "0221234567",
      "email": "info@clinica.com",
      "is_active": true,
      "doctors_count": 2,
      "assistants_count": 2,
      "created_at": "2024-01-15T10:00:00Z"
    }
  ],
  "meta": {
    "current_page": 1,
    "last_page": 1,
    "per_page": 15,
    "total": 2
  }
}
```

POST `/api/super-admin/clinics`

Access: Super Admin only

Request Body:

json

```
{
  "name": "Clinic B",
  "address": "45 Nile Street, Giza",
  "phone": "0237654321",
  "email": "info@clinicb.com"
}
```

Validation Rules:

Field	Rules
<code>name</code>	required, string, max:255
<code>address</code>	required, string
<code>phone</code>	required, string
<code>email</code>	required, email, unique

Success Response (201):

```
json
{
  "success": true,
  "message": "Clinic created successfully",
  "data": {
    "id": 2,
    "name": "Clinic B",
    "address": "45 Nile Street, Giza",
    "phone": "0237654321",
    "email": "info@clinicb.com",
    "is_active": true,
    "created_at": "2024-06-01T09:00:00Z"
  }
}
```

GET `/api/super-admin/clinics/{id}`

Success Response (200):

```
json
```

```
{
  "success": true,
  "message": "Clinic retrieved successfully",
  "data": {
    "id": 1,
    "name": "Clinic A",
    "address": "123 Main Street, Cairo",
    "phone": "0221234567",
    "email": "info@clinica.com",
    "is_active": true,
    "users": [
      { "id": 2, "name": "Dr. Sarah Ahmed", "role": "doctor" },
      { "id": 3, "name": "Mona Hassan", "role": "assistant" }
    ]
  }
}
```

PUT `/api/super-admin/clinics/{id}`

Request Body: Same fields as POST (all optional for partial update).

PATCH `/api/super-admin/clinics/{id}/toggle`

Activate or deactivate a clinic.

Request Body: None

Success Response (200):

```
json
{
  "success": true,
  "message": "Clinic has been deactivated.",
  "data": {
    "id": 1,
    "is_active": false
  }
}
```

3. Super Admin — Users

GET `/api/super-admin/users`

Query Parameters:

Param	Example	Description
<code>role</code>	<code>?role=doctor</code>	Filter by role
<code>clinic_id</code>	<code>?clinic_id=1</code>	Filter by clinic
<code>search</code>	<code>?search=ahmed</code>	Search by name or email
<code>is_active</code>	<code>?is_active=1</code>	Filter by active/inactive

Success Response (200):

```
json
{
  "success": true,
  "message": "Users retrieved successfully",
  "data": [
    {
      "id": 2,
      "name": "Dr. Sarah Ahmed",
      "email": "doctor@clinica.com",
      "phone": "01012345678",
      "role": "doctor",
      "is_active": true,
      "clinic": {
        "id": 1,
        "name": "Clinic A"
      }
    }
  ],
  "meta": { "current_page": 1, "total": 4 }
}
```

POST `/api/super-admin/users`

Request Body:

```
json
```

```
{
  "name": "Dr. Karim Nour",
  "email": "karim@clinicb.com",
  "password": "SecurePass123!",
  "password_confirmation": "SecurePass123!",
  "phone": "01098765432",
  "role": "doctor",
  "clinic_id": 2
}
```

Validation Rules:

Field	Rules
name	required, string, max:255
email	required, email, unique:users
password	required, min:8, confirmed
phone	required, string
role	required, in:doctor,assistant
clinic_id	required, exists:clinics,id

Success Response (201):

```
json
{
  "success": true,
  "message": "User created successfully",
  "data": {
    "id": 5,
    "name": "Dr. Karim Nour",
    "email": "karim@clinicb.com",
    "role": "doctor",
    "clinic": { "id": 2, "name": "Clinic B" }
  }
}
```

PUT `/api/super-admin/users/{id}`

Request Body: Any combination of user fields (all optional).

PATCH `/api/super-admin/users/{id}/toggle`

Success Response (200):

```
json
{
  "success": true,
  "message": "User has been deactivated.",
  "data": { "id": 5, "is_active": false }
}
```

4. Super Admin — Dashboard & Monitoring

GET `/api/super-admin/dashboard`

Success Response (200):

```
json
{
  "success": true,
  "message": "Dashboard data retrieved",
  "data": {
    "total_clinics": 2,
    "active_clinics": 2,
    "total_doctors": 4,
    "total_assistants": 4,
    "total_patients": 120,
    "total_appointments": 340,
    "appointments_today": 18,
    "appointments_this_month": 95
  }
}
```

GET `/api/super-admin/appointments`

Query Parameters:

Param	Example	Description
clinic_id	?clinic_id=1	Filter by clinic
doctor_id	?doctor_id=2	Filter by doctor
status	?status=completed	Filter by status
date	?date=2024-06-01	Filter by specific date
from	?from=2024-06-01	Date range start
to	?to=2024-06-30	Date range end

Success Response (200):

```
json
{
  "success": true,
  "data": [
    {
      "id": 1,
      "appointment_date": "2024-06-05",
      "start_time": "09:00",
      "end_time": "09:30",
      "status": "completed",
      "patient": { "id": 3, "name": "Ali Mohamed", "phone": "01055556666" },
      "doctor": { "id": 2, "name": "Dr. Sarah Ahmed" },
      "clinic": { "id": 1, "name": "Clinic A" }
    }
  ],
  "meta": { "current_page": 1, "total": 340 }
}
```

5. Doctor — Schedule

GET /api/doctor/schedules

Success Response (200):

json

```
{
  "success": true,
  "data": [
    {
      "id": 1,
      "day_of_week": 0,
      "day_name": "Sunday",
      "start_time": "09:00",
      "end_time": "13:00",
      "slot_duration": 30,
      "is_active": true
    }
  ]
}
```

POST `/api/doctor/schedules`

Request Body:

```
json
{
  "day_of_week": 1,
  "start_time": "10:00",
  "end_time": "14:00",
  "slot_duration": 30
}
```

Validation Rules:

Field	Rules
<code>day_of_week</code>	required, integer, between:0,6
<code>start_time</code>	required, date_format:H:i
<code>end_time</code>	required, date_format:H:i, after:start_time
<code>slot_duration</code>	required, integer, in:15,20,30,45,60

Success Response (201):

```
json
```

```
{
  "success": true,
  "message": "Schedule created successfully",
  "data": {
    "id": 2,
    "day_of_week": 1,
    "day_name": "Monday",
    "start_time": "10:00",
    "end_time": "14:00",
    "slot_duration": 30,
    "is_active": true
  }
}
```

6. Doctor — Appointments

GET `/api/doctor/appointments`

Query Parameters:

Param	Example	Description
<code>date</code>	<code>?date=2024-06-05</code>	Filter by specific date
<code>status</code>	<code>?status=pending</code>	Filter by status

Success Response (200):

json

```
{
  "success": true,
  "data": [
    {
      "id": 10,
      "appointment_date": "2024-06-05",
      "start_time": "09:00",
      "end_time": "09:30",
      "status": "confirmed",
      "notes": "Patient has a history of hypertension",
      "patient": {
        "id": 3,
        "name": "Ali Mohamed",
        "phone": "01055556666",
        "date_of_birth": "1985-03-12",
        "gender": "male"
      },
      "booked_by": { "id": 3, "name": "Mona Hassan" }
    }
  ]
}
```

PATCH `/api/doctor/appointments/{id}/status`

Request Body:

```
json
{
  "status": "completed"
}
```

Validation Rules:

Field	Rules
<code>status</code>	required, in:confirmed,cancelled,completed

Success Response (200):

```
json
```

```
{
  "success": true,
  "message": "Appointment status updated to completed",
  "data": { "id": 10, "status": "completed" }
}
```

7. Doctor — Prescriptions

POST `/api/doctor/prescriptions`

Request Body:

```
json
{
  "appointment_id": 10,
  "diagnosis": "Hypertension Grade 1",
  "notes": "Monitor blood pressure daily. Reduce salt intake.",
  "items": [
    {
      "medicine_name": "Amlodipine",
      "dosage": "5mg",
      "frequency": "Once daily",
      "duration": "30 days",
      "notes": "Take in the morning"
    },
    {
      "medicine_name": "Aspirin",
      "dosage": "81mg",
      "frequency": "Once daily",
      "duration": "30 days",
      "notes": null
    }
  ]
}
```

Validation Rules:

Field	Rules
appointment_id	required, exists:appointments,id
diagnosis	required, string
notes	nullable, string
items	required, array, min:1
items.*.medicine_name	required, string
items.*.dosage	required, string
items.*.frequency	required, string
items.*.duration	required, string
items.*.notes	nullable, string

Success Response (201):

json

```
{
  "success": true,
  "message": "Prescription created successfully",
  "data": {
    "id": 5,
    "diagnosis": "Hypertension Grade 1",
    "notes": "Monitor blood pressure daily.",
    "appointment": { "id": 10, "appointment_date": "2024-06-05" },
    "patient": { "id": 3, "name": "Ali Mohamed" },
    "items": [
      {
        "id": 9,
        "medicine_name": "Amlodipine",
        "dosage": "5mg",
        "frequency": "Once daily",
        "duration": "30 days",
        "notes": "Take in the morning"
      },
      {
        "id": 10,
        "medicine_name": "Aspirin",
        "dosage": "81mg",
        "frequency": "Once daily",
        "duration": "30 days",
        "notes": null
      }
    ],
    "created_at": "2024-06-05T11:30:00Z"
  }
}
```

GET `/api/doctor/prescriptions/{id}`

Success Response (200): Same structure as POST response above.

PUT `/api/doctor/prescriptions/{id}`

Request Body: Same as POST. Items array **replaces** all existing items.

8. Assistant — Patients

GET `/api/assistant/patients`

Query Parameters:

Param	Example	Description
<code>search</code>	<code>?search=ali</code>	Search by name or phone

Success Response (200):

```
json
{
  "success": true,
  "data": [
    {
      "id": 3,
      "name": "Ali Mohamed",
      "phone": "01055556666",
      "email": "ali@email.com",
      "date_of_birth": "1985-03-12",
      "gender": "male",
      "address": "10 Hassan Street, Cairo"
    }
  ],
  "meta": { "current_page": 1, "total": 45 }
}
```

POST `/api/assistant/patients`

Request Body:

```
json
{
  "name": "Fatma Ibrahim",
  "phone": "01099887766",
  "email": "fatma@email.com",
  "date_of_birth": "1992-08-25",
  "gender": "female",
  "address": "22 Tahrir Square, Cairo"
}
```

Validation Rules:

Field	Rules
name	required, string, max:255
phone	required, string, unique:patients,phone,NULL,id,clinic_id,{clinic_id}
email	nullable, email
date_of_birth	nullable, date, before:today
gender	required, in:male,female
address	nullable, string

Success Response (201):

```
json
{
  "success": true,
  "message": "Patient registered successfully",
  "data": {
    "id": 25,
    "name": "Fatma Ibrahim",
    "phone": "01099887766",
    "email": "fatma@email.com",
    "date_of_birth": "1992-08-25",
    "gender": "female",
    "address": "22 Tahrir Square, Cairo",
    "created_at": "2024-06-05T08:00:00Z"
  }
}
```

9. Assistant — Appointments

GET (/api/assistant/available-slots)

Returns the list of open time slots for a specific doctor on a specific date.

Query Parameters:

Param	Required	Example
<code>doctor_id</code>	Yes	<code>?doctor_id=2</code>
<code>date</code>	Yes	<code>?date=2024-06-06</code>

Success Response (200):

```
json
{
  "success": true,
  "message": "Available slots retrieved",
  "data": {
    "doctor": { "id": 2, "name": "Dr. Sarah Ahmed" },
    "date": "2024-06-06",
    "slot_duration_minutes": 30,
    "available_slots": [
      { "start_time": "09:00", "end_time": "09:30" },
      { "start_time": "10:00", "end_time": "10:30" },
      { "start_time": "11:00", "end_time": "11:30" }
    ]
  }
}
```

Error — No schedule on that day (422):

```
json
{
  "success": false,
  "message": "The doctor has no schedule on Thursday."
}
```

POST `/api/assistant/appointments`

Request Body:

```
json
```

```
{
  "doctor_id": 2,
  "patient_id": 25,
  "appointment_date": "2024-06-06",
  "start_time": "10:00",
  "notes": "Patient complains of chest pain for 3 days"
}
```

Validation Rules:

Field	Rules
doctor_id	required, exists:users,id (role must be doctor, same clinic)
patient_id	required, exists:patients,id (same clinic)
appointment_date	required, date, after_or_equal:today
start_time	required, date_format:H:i (must be an available slot)
notes	nullable, string

Success Response (201):

```
json
{
  "success": true,
  "message": "Appointment booked successfully",
  "data": {
    "id": 42,
    "appointment_date": "2024-06-06",
    "start_time": "10:00",
    "end_time": "10:30",
    "status": "pending",
    "notes": "Patient complains of chest pain for 3 days",
    "doctor": { "id": 2, "name": "Dr. Sarah Ahmed" },
    "patient": { "id": 25, "name": "Fatma Ibrahim" },
    "booked_by": { "id": 3, "name": "Mona Hassan" }
  }
}
```

Error — Slot already booked (409):

json

```
{
  "success": false,
  "message": "This time slot is already booked."
}
```

PUT `/api/assistant/appointments/{id}`

Reschedule an appointment.

Request Body:

```
json

{
  "appointment_date": "2024-06-08",
  "start_time": "11:00"
}
```

Business Rule: Cannot reschedule a `completed` or `cancelled` appointment.

Error — Already completed (422):

```
json

{
  "success": false,
  "message": "A completed appointment cannot be rescheduled."
}
```

DELETE `/api/assistant/appointments/{id}`

Cancel an appointment.

Success Response (200):

```
json

{
  "success": true,
  "message": "Appointment cancelled successfully",
  "data": { "id": 42, "status": "cancelled" }
}
```

GET `/api/assistant/appointments`

Returns today's appointments for the assistant's clinic.

Query Parameters:

Param	Example	Description
<code>date</code>	<code>?date=2024-06-06</code>	Override date (default: today)
<code>status</code>	<code>?status=pending</code>	Filter by status

Success Response (200):

```
json
{
  "success": true,
  "data": [
    {
      "id": 42,
      "appointment_date": "2024-06-06",
      "start_time": "10:00",
      "end_time": "10:30",
      "status": "pending",
      "patient": { "id": 25, "name": "Fatma Ibrahim", "phone": "01099887766" },
      "doctor": { "id": 2, "name": "Dr. Sarah Ahmed" }
    }
  ]
}
```

10. HTTP Status Code Reference

Code	Meaning	When Used
200	OK	Successful GET, PUT, PATCH, DELETE
201	Created	Successful POST (new resource)
204	No Content	Successful DELETE with no body
401	Unauthorized	Missing or invalid token
403	Forbidden	Valid token, wrong role

Code	Meaning	When Used
404	Not Found	Resource doesn't exist
409	Conflict	Double-booking, duplicate resource
422	Unprocessable Entity	Validation failure or business rule
429	Too Many Requests	Rate limit exceeded
500	Internal Server Error	Unexpected server-side error

Maintain this document alongside any route changes. Export to Postman Collection for team use.